Threat evolution Q2 2016

GROUP IB
GLOBAL CYBER SECURITY COMPANY

Table of contents

Introduction 3

Summary: Threats to the Financial Sector in Russia 4

Summary: Threats to the Financial Sector, Global 6

Summary: Threats to the Government sector 8

Forecasts for Q3 2016 9

Threats to the Financial Sector in Russia 10

Targeted attacks 10

Banking Trojans for PC and Android 10

Attacks on ATM and POS terminals 12

Threats to the Financial Sector, Global 14

Targeted attacks 14

Banking threats for PC and Android 15

Attacks on POS terminals 21

Data leakage 21

Threats to the Government sector 23

APT 23

Hacktivism 23

Data leakage 26

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features such threats with a particular focus on the USA, Europe, Russia and Australia. This document also provides a comprehensive description of threats for governments, including hacktivists' attacks, targeted attacks supported by government and significant data leaks.

Researchers observe that malware used to target victims in Russia is often then 'exported' to other countries, that is why we believe it is essential to inform our international clients about Russian threats along with those targeting them directly.

To collect data and inform our clients, we analyze various botnets and malware detected while reacting to the most dangerous incidents, monitor the most secretive underground hacker forums and accumulate information on new trends, threats and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Summary: Threats to the Financial Sector in Russia

Targeted attacks

Hackers conduct targeted attacks on banks in order to steal money or get access to payment systems, POS terminals and ATMs. In Q2 2016 activity of 3 criminal groups was recorded:

- Attacks conducted by the Buhtrap gang on Russian banks.
- Targeted attacks on Russian banks using Andromeda and RMS.
- A targeted attack using Cobalt Strike.

Banking Trojans for PC and Android

During the reporting period Group-IB specialists detected attacks on Russian banks using specific Trojans. The vast majority of Trojans for PC were used to deplete accounts of businesses, while mobile Trojans were used to steal money from accounts of individuals. In Q2 2016 Group-IB specialists observed activity of the following banking Trojans:

- Trojans for PC: Lurk, ProxyAdder, RTM, Jupiter, Buhtrap, Ranbyus. It is worth noting that Jupiter and RTM are new Trojans, which currently target only Russian banks. At the moment criminals are known to be enhancing their functionality, which can make these Trojans a dangerous threat in the future.
- Mobile Trojans: FakeInst.ft, Tiny.z, GM Bot, Agent.sx, Cron, Honli, Opfake, Agent.BID. Leakage of GM Bot source code provoked an expected appearance of a new version of this Trojan targeting Russian banks.

In Q2 2016 members of several hacker groups were arrested and sentenced to prison for thefts from bank accounts of Russian and Ukrainian companies:

- In April 2016 members of a criminal group, which had successfully robbed businesses' bank accounts since 2009, were sentenced to prison. They used such malicious programs as Hodprot and Carberp. One of the sentenced hackers was Dmitry Fedotov, known under the nickname Paunch, the author of the infamous "Blackhole" and "Cool Exploit Kit" exploit packs, as well as the malware obfuscation service Crypt.am.
- On June 1, 2016 law enforcement officials announced the arrest of 50 members of the Lurk gang. Since 2011 the group had stolen 1.7 billion rubles. In 2016 the group refocused on APT attacks and started using leaked Buhtrap source code in additional to their banking Trojan Lurk.

Attacks on ATM and POS terminals

During the reporting period Group-IB specialists detected activity of one criminal group targeting POS terminals and incidents of tools designed to steal money from ATMs offered for purchase.

- Specialists detected equipment designed for thefts from ATMs ("BlackBox") available for purchase. This tool enables criminals to hack an ATM and make it dispense money. An increase in the number of attacks using this equipment was recorded.
- Researchers detected activity of the Romanich criminal group, which used various Trojans to infect POS terminals in Russia, obtain bank card data and withdraw money in the US. The criminals are purportedly located in Romania.

Data leakage

During the reporting period Group-IB specialists detected activity from several groups of malicious insiders. They continued creating services selling confidential bank data and promoting them on underground platforms. Also, we recorded an incident where VK.ru social network's database was offered for sale.

- During Q2 2016 we detected 6 services selling confidential bank data related to 3 Russian banks.
- VK.ru's social network database appeared on the underground service The Real Deal.

Summary: Threats to the Financial Sector, Global

Targeted attacks

During the reporting period Group-IB specialists detected targeted attacks on banks all over the world. Criminals used infection vectors similar to that used in attacks on Russian financial institutions. Also, researchers recorded attacks on the SWIFT payment network.

- Starting in 2016 we saw a sharp increase in the number of targeted attacks on banks all over the world along with attacks on their clients. Hacker tactics were similar to those used in attacks on Russian banks. Once criminals gained access to a bank's network, attackers conducted transfers using the SWIFT system. In Q2 2016, researchers detected activity of several criminal groups. Also, security specialists detected a targeted attack on Middle East banks using the Mimikatz program and spy software;
- Attacks of an unidentified group on the SWIFT system in various banks all over the world. At the moment, researchers know about 4 incidents.

Banking Trojans for PC and Android

Like in Russian cases, Trojans for Android were used to steal money from the accounts of individuals, while PC Trojans were used both for attacks on individuals and companies. All malicious programs targeting clients of foreign banks, which are described in this report section, are not used on the territory of CIS countries.

Trojans for Android:

- The most actively used Trojans were the infamous GM Bot and Marcher. Their main functions are grabbing victim's bank credentials, using phishing dialog windows of Google Play and WhatsApp and HTML/JS injects for banking apps designed to collect information.
- It is also known that the author of GM Bot was banned on all major underground platform, that's why he can no longer mass market his product.
- New Trojans for the Android operating system appeared: Abrvall and Bilal. They are designed to grab bank card data (using injects for Google play, Skype, and Whatsapp) and bank account credentials (using injects developed for mobile banking applications) and can intercept SMS messages and run specified USSD requests.
- An updated version of the Android-KNL Trojan (aka Marcher) was released. The key difference of Marcher 2.0 from previous versions is a new module that allows it to inject mobile browsers.
  A new bot ("Exo bot") designed based on Marcher was released. Marcher's developer was also banned on forums.
- Researchers detected sales of a new loader for Android apps masquerading as a racing game, which is distributed via Google Play.

Trojans for PC

- During the reporting period Group-IB specialists detected attacks on banks in Europe, the US and Australia using the following banking Trojans: Gootkit, Dridex, ISFB, Qadars, Tinba, Vawtrak, Zeus;
- We saw a drop in the activity of Corebot. It's worth reiterating that this banking Trojan with web injection capabilities has the function to remain persistent on the infected system and has incorporated a new domain generation algorithm (DGA). In Q1 2016 it was used to attack banks of North America, the Asia-Pacific region and Europe.

- Criminals used GozNym, a Trojan hybrid spawned from the Nymaim loader and the banking malware ISFB (Gozi), to conduct attacks against U.S. and Canadian banks, stealing millions of dollars so far, as the IBM X-Force Research team had informed in April.
- In Q2 2016 Group-IB specialists detected numerous offers of ISFB source code or recent Trojan versions for sale on underground forums. It's worth reminding that older versions of the ISFB had been published online earlier.
- An announcement on new banking bot for Windows named Midas bot available for lease was recorded on a deep web hacking forum. The author of this publication says that this bot is private and has the inject functions.
- Attacks on the SWIFT system were detected on several banks.
- An exploit for local privilege escalation (LPE) for a 0day vulnerability in win32k.sys available for purchase was detected on an underground resource.
- A new banking Trojan named Panda Banker, designed based on the Zeus source code, is being actively used in attacks against UK and US banks with more than 55,000 victims at the moment.

Threats to POS terminals

A new Trojan for attacks on POS terminals named InsPOS (InsolentPOS) was released.

Data leakage

During the reporting period Group-IB recorded incidents of users' databases for sale (Linkedin, MySpace, Vkontakte, etc.). This data is sold on the underground platform The Real Deal; also, it can be bought from a user hiding under the name Tessa. Databases were compromised in 2012, however, it was only offered for sale recently. Also, data leaks from Invest Bank, a bank in the United Arab Emirates, and Acer were recorded.

- The Bozkurtlar hacker group released customer data of a bank from UAE identified as Invest bank and the Qatar National Bank.
- A new underground resource named The Real Deal selling databases of various resources (Linkedin, MySpace, Vkontakte, etc.) was detected.
- Acer notified its customers of a major data breach the company had suffered via its online store.

Summary: Threats to the Government sector

Targeted attacks

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks on critical infrastructures. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. In Q2 2016 two active campaigns were detected:

- Chinese APT «Mofang»;
- Cyber espionage campaign in Ukraine named “Operation Groundbait”

Hacktivism

- In Q2 2016, hacktivists conducted over 1900 attacks on various online resources. 826 detected attacks were of “page replacement” type (Deface) and 1027 attacks were DDoS attacks (Denial of Service) targeting government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Israel, the USA, Turkey, Russia, Peru, the UK, India, Japan and Brazil. The most active gangs which are believed to have concentrated their attacks on one country were ActivistHack (attacks on Turkish resources), DownSecBelgium, AnonymousBelgie (attacks on Belgium government resources), DownSecFrance (attacks on French resources), as well as groups which identified themselves with a certain country: AnonyOpTurkey, Anonymous Nigeria, Anonymous Africa, Anonymous Peru, IndiaHackOps and Peruvian Hackers.

Data leakage

During the reporting period analysts detected activity of the Bozkurtlar criminal group, which posted compromised information about Qatar's top government officials and their family members.

Also, various hacker attacks related to the US presidential election campaign were recorded.

- In addition to Qatar bank data breach Bozkurtlar leaked files on members of the Qatari royal family, government and army officials, as well as people listed as working for intelligence agencies of several countries.
- The Bill, Hillary and Chelsea Clinton Foundation’s network and the website of the US Democratic Party suffered hacker attacks.

Forecasts for Q3 2016

Based on the threats detected, we can forecast the following future incidents in Russia:

1) The amount of attacks using the Jupiter, RTM and ProxyAdder Trojan programs is expected to increase;
2) Activity of the Lurk group stopped, because a major part of gang's members were arrested. However, there is still a risk of source code leakage or renewed activity of other members.
3) Availability of BlackBox, a tool designed for attacks on ATMs, for purchase in open sources will provoke an increase in the number of thefts from ATM machines.
4) Active use of Android Trojans will continue to grow. A new modification of Android-KNL with web injects will enable criminals to conduct more sophisticated attacks on clients and collect any data during bank operations in the browser.

Based on the threats detected, we can forecast the following future incidents in Europe, the USA, and Australia:

1) The amount of attacks using GM Bot will decrease, but its 'competitors' Marcher and Abrvall (and their modifications) will try to take its place on the market;
2) The fraudulent activity using ISFB (Gozi) and its modification Nymaim is expected to be high.
3) The amount of attacks using such banking Trojans as Gootkit, Dridex, Vawtrak, Qadars, Panda, Tinba will continue at the same level.
4) Just after the arrest of the Lurk gang, Russian and foreign cybercrime groups stopped using the most popular exploit kit "Angler", which had purportedly been developed with participation of Lurk members. Due to this fact we expect an increase in the amount of incidents using Neutrino Exploit Kit and other exploit packs.
5) Criminals can start actively use a new Trojan named Midas bot in order to deplete bank accounts.
6) A new modification of Android-KNL with web injects will enable criminals to conduct more sophisticated attacks on clients and collect any data during bank operations in the browser.

Threats to the Financial Sector in Russia

Targeted attacks

APT name	Regions attacked	Related notifications	Operation start
Targeted spam emails with a malicious attachment containing the remote manipulator system (RMS)	Russia	CP-1408	September 2015

On May 4th, 2016 an attack was conducted by sending emails with an archive attached containing a malicious .exe file. Phishing emails were sent posing as 'info@bankir.ru' and targeted Russian banks only. When a victim opened the attachment, it downloaded a modified remote control server. Previously a similar spamming attack was detected in September 2015, when it masqueraded as an employee of the company Gazprom Neft using the email address info@gaz-prom-neft.ru. The attachment also contained modified RMS.

Banking Trojans for PC and Android

Malware name	Regions attacked	Detection	Notification
GM Bot (other names: Mazar, SlemBunk, Bankosy, Acecard, Slempo)	Australia, Europe, USA, Russia	October 2014	CP-1393

Earlier GM Bot hadn't been used to attack Russian financial institutions. However, in January 2016 GM Bot source code leaked online, which enabled hackers to modify it to attack clients of Russian banks. In early April 2016 a new version of GM BOT was detected. According to analysis of the web injects' configuration file, the malware now targets the following Russian financial institutions:

- VTB24 (ru.vtb24.mobilebanking.android)
- Tinkoff Bank (ru.tcsbank.wallet)
- Gazprombank (Telecard app) (ru.bpc.mobilebank.android)
- Alfa Bank (ru.alfabank.mobile.android)
- Sberbank (ru.sberbankmobile)
- Visa QIWI Wallet (ru.mw)

This Trojan version was distributed under the name "FlashPlayer.apk".

Malware name	Detection	Notification
Jupiter	April 2016	CP-1417

In April 2016 Jupiter, a new banking Trojan, was detected by researchers. In June 2016 a message on search for partners to distribute the Trojan was published on an underground forum. At the moment the Trojan is being actively used in attacks against Russian banks.

Jupiter contains a variety of modules designed to compromise data on the victim's machine. The author described the following features of the Trojan:

- The malware is able to run without root privileges.
- It uses a polymorphic engine to make it hard for virus scanners to detect the body of the malware.
- It supports all versions of OS Windows from XP to 10 (x32/x64).
- It contains an administrative panel. In order to connect with the administrative panel, the Trojan uses AES encryption over HTTP + Curve25519 (elliptic curve cryptography).
- It supports the function Backconnect (permanent connection with the administrative panel) and has the ability to obtain socks5, cmd or WebDAV access to all local files of the infected machine or to the local network.
- The Trojan has the ability to self-replicate, it copies itself to flash drives connected to the infected machine, and is capable of self-spreading over the local network.
- To reduce generated traffic, the malware uses an encrypted VFS container, where reports, configurations and modules are located.
- The Trojan does not have its own .exe file, which complicates its detection by antivirus software.

To compromise data on the infected machine the Trojan uses various modules:

- A web injection module (injections are in Zeus configuration format, so they can be directly transferred from the administrative panel).
- A form grabber designed to compromise authentication data of the victim. It supports the following web browsers: Chrome, Mozilla Firefox, Internet Explorer (including support of Microsoft Edge, Windows 10's new browser).
- Keylogger. It supports a number of languages and captures keystrokes during all processes.
- A file grabber designed to search for and download specific files on the attacked computer using various 'masks'.
- A screenshot logger enables the criminal to take screenshots of certain windows and send them to the administrative panel. It uses window titles as a filter.
- Grabbers of FTP, POP3, certificates.
- A module designed to intercept bank card magnetic stripe data (Track1 + Track2).

Malware name	Detection	Regions attacked
RTM	December 2015	Russia

This Trojan targets online banking and payment systems. Group-IB analysts detected incidents of scanning infected machines for possible communications with online banking systems of Sberbank, VTB 24 and payment systems. In particular, the Trojan scans for addresses containing the following substrings: *bsi.dll?, online.payment.ru, /sbi.sberbank, bankline.ru/servlets/ibc, faktura.ru, /iclient/, ibank2, bco.vtb24.ru*.

The modules that extends the basic program functionality are allegedly designed for both 32-bit systems and 64-bit systems.

Attacks on ATM and POS terminals

Group-IB specialists detected announcements on sales of the tool designed for stealing money from ATMs named BlackBox.

Tool name	Detection	Notification
BlackBox	March 2016	CP-1422

Criminals used the following infection vector to attack ATMs:

- A criminal switches off the ATM and opens up its upper casing.
- He disconnects the ATM's cash dispenser from the core computer controlling the device plugging a USB-based circuit board into the controller to fool the ATM's core into thinking it is still connected to the cash dispenser.
- The attacker then attaches the dispenser to an external electronic device - the so-called 'Black Box' – his own smartphone with specific software installed to receive remote commands to control the dispenser.
- The ATM switches on and is capable of operating normally (except for usual cash dispensing).
- Criminals send instructions to the smartphone which makes the ATM dispense money; the attacker sending the commands works remotely, and the mules are the ones at the ATMs.

Price for 'BlackBox' in detected selling offers:

1) Initial deposit of 2000 USD for equipment;

2) Equipment rental – 1050 USD per month.

Security specialists also detected an attack on Russian banks that involved infecting POS terminals.

Operation name	Regions attacked	Related notifications	Operation start
Attack of the Romanich group on banks	Russia	CP-1407	May 2016

In May 2016 Group-IB specialists detected attacks on clients of Russian banks conducted by the group named Romanich, which used JackPos and Cerebrus malware as well as a new Trojan GrepBot HTTP Botnet.

The JackPos malware designed to attack POS terminals is used to steal bank card data. At the moment this Trojan is available in open sources.

Like JackPos, the Cerebrus malware, which is also known as CenterPOS, targets POS terminals. The Trojan is used as a 'memory scraper', collecting bank card information. The malware encrypts data grabbed on the infected computer using the TripleDES algorithm and sends it to the C&C server via HTTP POST.

Since early May the GrepBot HTTP Botnet malware has been distributed on underground forums. The Trojan is designed to steal bank card data including Track2 or Track1 + Track2 dumps for POS systems.

Criminals are known to have attacked clients of the following banks:

- MTS Bank
- Sberbank

- Tinkoff Bank
- Promsvyazbank
- Bank Saint Petersburg
- VTB24
- Alfa Bank
- Vozrozhdenie Bank
- Bank “Petrokommertz” *(Otkritie Financial Corporation)*

We expect that this group will continue their criminal activity.

Threats to the Financial Sector, Global

Targeted attacks

APT name	Regions attacked	Operation start
Targeted attack on banks in the Middle East	Middle East	2016

In May 2016 researchers identified a wave of hacker attacks on financial institutions in the Middle East. During the campaign criminals sent multiple emails containing malicious attachments targeting banks. The threat actors are believed to be performing initial reconnaissance against potential targets.

The attackers sent emails containing macro-enabled XLS files to employees working in the banking sector. Subjects of the messages used in the attacks were related to IT Infrastructure such as 'Server Status Report'.

The macro runs successfully only on the Windows Vista operating system. After the macro successfully creates the scheduled task, the dropped script launches and then downloads a customized version of Mimikatz and a BAT file used to collect information on the attacked system, including data on the current authorized user, host name, network configuration, individual and group accounts, active processes, etc.

APT name	Related notifications	Operation start
Targeted attack on the SWIFT system	CP-1411	December 2015

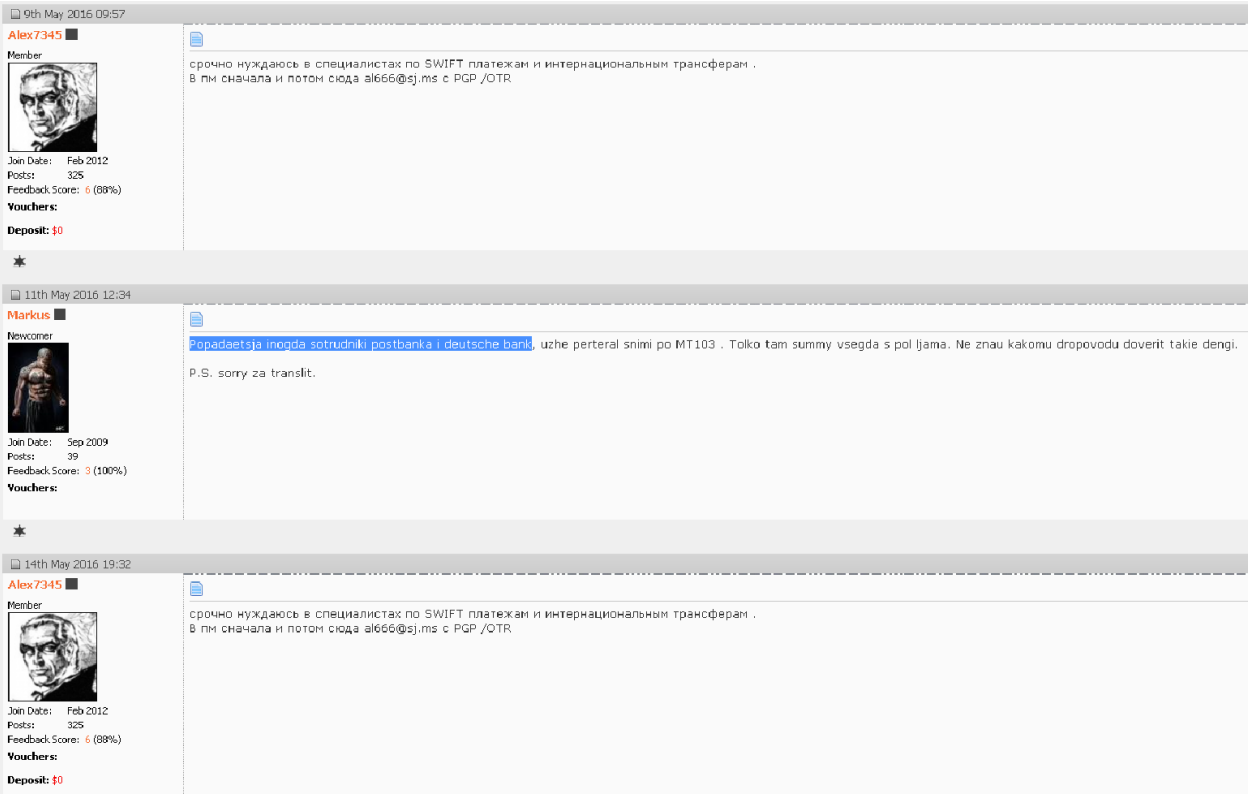
Criminals conducted attacks on the SWIFT system attempting to perform unsanctioned transactions at the Central Bank of Bangladesh and Vietnam's Tien Phong Commercial Joint Stock Bank (TPBank).

In February 2016 hackers sent 35 fraudulent money transfer requests to withdraw millions from the systems of Bangladesh Bank. The majority of the transactions were halted, however, criminals managed to get $81 million.

In December 2015 hackers unsuccessfully attempted to perform one fraudulent transaction to withdraw 1.2 mill euro from Tien Phong Bank to a Slovenian bank.

Attacks on the SWIFT messaging system were also detected in 2015, when Ecuadorean bank Banco del Austro and a bank in the Philippines (its name is not known) were purportedly robbed by the Lazarus gang.

Also, in May 2016 analysts detected messages containing information about preparation of attacks using the SWIFT system on a Russian-speaking deep web hacking forum.



Banking threats for PC and Android

Malware name	Regions attacked	Detection
GM Bot (other names: Mazar, SlemBunk, Bankosy, Acecard, Slempo)	Australia, Europe, the USA, Russia	October 2014

In Q2 2016 researchers detected the following attacks on banks of Australia, Europe, and the USA using GM Bot:

ANZ
Bankwest
HSBC
Commbank
Bank of America
Chase
RBS
Garanti
Berlinerbank
Commerzbanking
Postbank
ING bank
SuncorpBank
Banque Caisse d'Epargne
Banque Palatine
Banque Populaire
Credit Agricole
La Poste
Le Crédit Lyonnais
Bnpparibas

Bawag PSK
Comarch ERP
Alior bank
Deutsche bank
Webmoney

Also, it is worth noting that the author and vendor of the original GM Bot – a criminal named GanjaMan – was banned on major underground forums. The reason of ban was a financial claim of a customer who didn't receive promised technical support to the purchased product.

Therefore, GanjaMan cannot sell its product on forums. It can provoke an increase in competition at the market of Android Trojans and push GM Bot from the market.

GanjaMan purportedly continues developing and selling the Trojan in private.

Also, it's worth reminding that a license to sell the first version of GM Bot was bought by a user with the nickname GM_Project. The malware is known to be sold under the name GM-BOT v.1/Mazar.

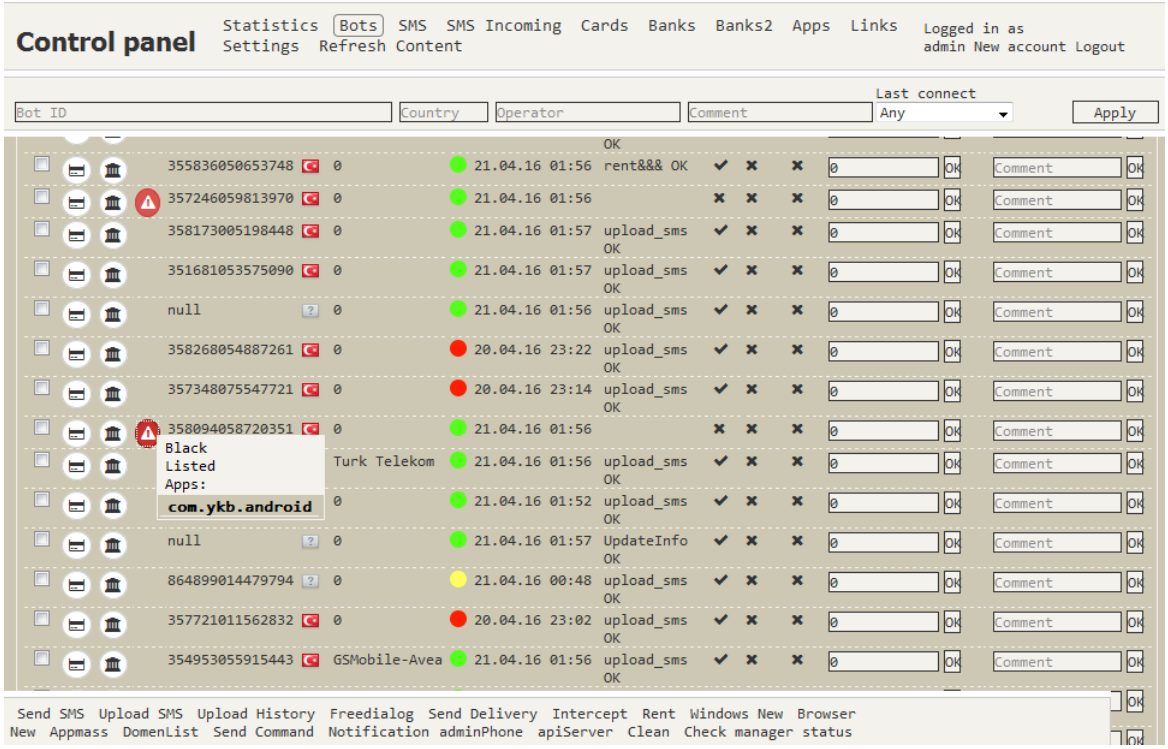
Malware name	Regions named	Detection	Notification
Abrvall	All countries except Russia	April 2016	CP-1398

An announcement on new banking malware for Android devices available for purchase was recorded on a deep web hacking forum. The Trojan is designed to collect bank card data (using injects for Google play, Skype, and Whatsapp) and bank accounts (using injects for mobile banking apps). Also, the program has the functionality to manipulate SMS messages (furtively sending and intercepting SMS on phones with Android versions up to 6.0). This Trojan doesn't operate in Russia and the CIS region. It is detected to be sold under the name Abrvall.

Malware name	Regions attacked	Detection	Notification
Android-KNL (aka Marcher) 2.0	All countries except Russia	August 2015 – the first version appeared April 2016 – the malware update was released	CP-1280-2

A new version of the mobile banking Trojan Android-KNL (aka Marcher) was released. This malware is designed to compromise bank card data and credentials to enter online banking systems using fake dialogs masquerading as Google Play, HTML injects for Android apps and **web injects for mobile browsers**. Also, the Trojan can block the victim's device in order to ransom money for unlocking. In addition to abovementioned features, the malware is able to manipulate SMS messages (on all Android versions), phone calls and USSD requests. According to its author, it does not operate on the territory of Russia.

Samples of the first Marcher version were detected to attack Australia and Europe during the reporting period. In particular, a sample targeting banks of Poland was detected.



However, soon the seller was blocked on underground forums, like in the case of GanjaMan. Meanwhile Group-IB specialists have noticed that the Marcher bot is still active, which likely means that it is still available for purchase in private.

Just after the author of Marcher was blocked, a new Trojan based on the Marcher source code appeared.

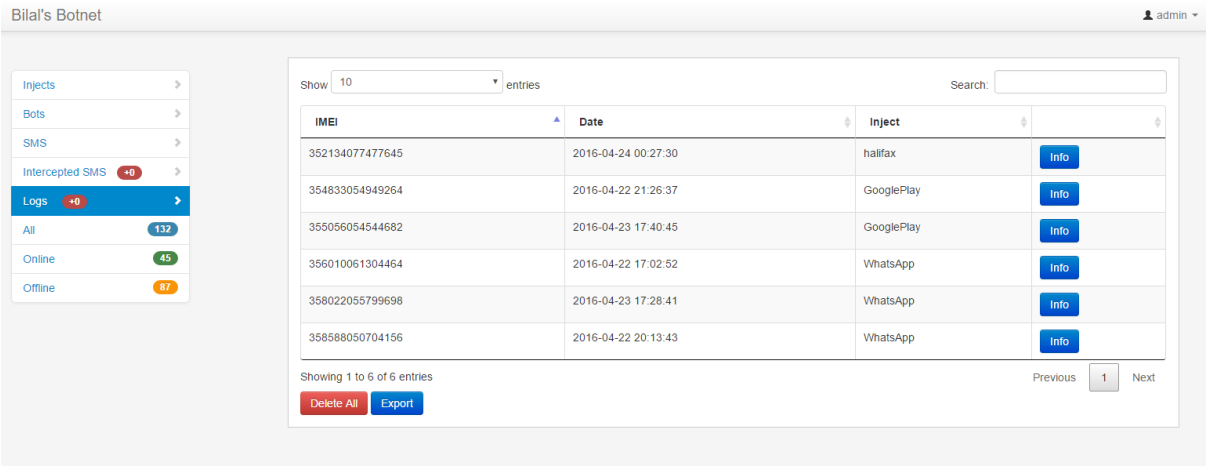
Malware name	Regions attacked	Detection	Notification
Exo bot	All countries except Russia	June 2016	CP-1423

In comparison with Marcher, the Exo bot contains the following additional functions:

- It supports the Android version 6.0.
- Enhanced functionality of web injects including a version for Android 6.0.
- Improved control panel.
- Regular check of a list of installed apps to control the operation of web injects.
- It generates a list of domain names, which complicates its detection by AV.

Malware name	Regions attacked	Detection	Notification
Bilal's Botnet	All countries except Russia	March 2016	CP-1400

The Bilal's Botnet banking Trojan has the functionality to silently capture and send SMS messages on Android versions up to 6.0, run USSD requests and divert calls. The Trojan is designed to collect bank card data (using web injects for Google play, Viber, and WhatsApp) and bank accounts (using injects for mobile banking apps). This malware does not operate in Russia.



Specialists detected two new loaders for Android apps, which allowed cybercriminals to spread their malicious programs.

Threat name	Detection	Notification
Loader masking as a game in Google Play	June 2016	CP-1418

Researchers detected the following application available for purchase on underground resources: a loader posing as a racing game, which can be downloaded in Google Play. The loader is connected to AppsFlyer, a marketing analytics platform designed to promote mobile apps and attribute mobile traffic. It operates on all android versions.

Threat name	Detection	Notification
C2H5OH loader	June 2016	CP-1414

The loader has the following functionality:

- Operation on all Android versions (2.2 and higher).
- It needs minimum privileges and operates stealthily.
- Self-update.
- Controlled from social networks and doesn't require an administrative panel.
- Anti-debugging techniques and social engineering.
- Code obfuscation.
- Multilingual capability.
- Setting any landing page when it launches.

Threat name	Detection	Notification
Midas bot	April 2016	CP-1406

An announcement on a new banking bot Midas available for lease was detected on an underground forum. It does not need root privileges, operates on Windows versions from XP to 10, has functions of form grabber, keylogger and web injections. It is also able to capture certificates and bank card dumps (Track1/Track2).
The price of its lease is high– 12,000 USD per month, however, as is seen from description of its functions, the bot can be a serious threat for banks.

Threat name	Detection	Regions attacked	Notification
ISFB (Gozi)	2013	Australia, Europe	CP-1396

In March-April 2016 Group-IB specialists detected an increase in the number of messages on underground forums that contained offers of the ISFB banking Trojan's source code for sale and its new version for lease.

- 2 announcements on the source code of the current version available for purchase.
- 2 messages on the ISFB bot available for lease.
- A pack with VNC module on sale.

It bears mentioning that source codes of the Trojan are available on public resources due to leaks in November 2015 and March 2016. However, its underground vendors say that they offer new versions of the malware, which are not available on public resources. Purportedly, this new version is a modification of GozNym.

It's worth reminding that the ISFB Trojan supports web injects for Chrome, IE, Firefox, and contains modules similar to those of infamous banking Trojans Zeus and SpyEye.

Threat name	Detection	Regions attacked
GozNym	April 2016	North America Europe

Several US and Canadian banks suffered thefts using a new malicious program named GozNym. It was developed based on the Nymaim loader and the banking Trojan ISFB (Gozi).

Threat name	Detection	Notification
0day exploit for the win32.sys vulnerability	May 2016	CP-1409

Security specialists detected chatter on an underground malware forum discussing an exploit for local privilege escalation (LPE) for a 0day vulnerability in win32k.sys being openly sold. The initial price of 95,000 USD was then reduced to 85,000 USD.

Its vendor says that it is able to escalate privilege level up to SYSTEM for any given process and execute arbitrary code *in Ring0.*

Also, researchers observed activity of the following banking Trojans:

Name	Detection	Attacked countries	Examples of the attacked banks
Dridex	2012	UK France Spain Australia	Fbnbank Barclays Santander Societegenerale Bancopopular Humebank Labanquepostale
Gootkit	2014	UK Spain	Lloyds Tsb

		Italy France Sweden Germany New Zealand Belgium Netherlands Canada USA	Halifax Bankofscotland Lacaixa Bbva Credit-Agricole Bnpparibas Scotiabank Royalbank Bmo Deutsche-Bank Commerzbank Hsbc
Qadars	2013	Australia	Commbank Suncprp Banksa Bankwest Boq Adelaidebank Bankofmelbourne
Tinba	2012	Australia Canada USA UK France	Banksa Bankofmelbourne Stgeorge Anz Nab Westpac Commbank Cibc Desjardins Tangerine Pcfinancial Barclays Halifax Lloydsbank Santander Hsbc Citi Bankofscotland Banquepopulaire
Vawtrak	2013	USA UK	Natwest Rbs Ulsterbank Bankofamerica Tdbank Chase Citibank Lloydsbank Bankofscotland Usaa Wellsfargo Citizenscommercialbanking

			Citibank 53.Com Capitalone

Attacks on POS terminals

Malware name	Detection	Notification
InsPOS/InsolentPOS	May 2016	CP-1413

Information on a new Trojan designed to attack POS terminals available for purchase was detected on several underground forums. This malware enables criminals to steal data stored on the magnetic stripe of bank cards (Track 1 + Track 2). According to its author, the Trojan cannot be detected by AV and is able to successfully bypass ESET Smart Security 9 and Kaspersky Antivirus security systems in real time.

Data leakage

- Recently media has widely covered leaked databases of Linkedin, Twitter and other popular resources' accounts, which are now for sale. It is established that the source of this information is a new dark web illegal marketplace The Real Deal and the hacker who is allegedly behind these megabreaches is hiding under the nickname Tessa. It is also believed that the data was accessed in 2012-2013 years. At the moment, databases of the following websites are currently available on the The Real Deal resource:
  - vk.com
  - fanpage.gr
  - Myspace
  - LinkedIn
  - Fling.com
  - r2games
  - wordpress logins
  - 17.media
  - Neopets
  - euromodel-online.eu
  - zepo.in
  - forums.bluehost.com
  - forums.hostsearch.com
  - invisionmodding.com
  - openraid.org
  - pspiso.com
  - forums.devarticles.com
  - xbox360iso.com
  - dcemu.co.uk
  - blu-rayiso.com
  - 3dsiso.com
  - lookbook.nu
  - seochat.com
- The Bozkurtlar hacker group broke the Qatar National Bank's network and stole sensitive personal and financial customer data, including that of the wealthiest and the most powerful people in the country.
- Bozkurtlar also released financial information of UAE InvestBank's clients and employees. Hackers dumped 10 GB of bank data including internal files and financial documents, around 100,000 payment card numbers, account statements of over 3,3 thousand clients, files related to bank transactions, information on bank's employees, documents involved in land deals, passport scans, etc.

  The database contains information on both clients and all bank's employees, including their phone numbers, email and home addresses.

  InvestBank representatives said that all compromised data was stolen in December 2015.

- Acer's web store suffered data breach. Hackers managed to access total payment card information: credit card holder name, address, card number, expiration date, CVV codes. Almost 35,000 customers from the USA, Canada and Puerto Rico became victims of the attack.

Threats to the Government sector

APT

APT name	Regions attacked	Operation start
Mofang	India, Germany, US, Canada, Singapore, South Korea, Myanmar	2012

Fox-IT has published results of a study on the spy ring Mofang. It is allegedly a Chinese spy APT operation supported by the government. The group uses specific malicious tools (ShimRat and ShimRatReporter) spread via spear-phishing emails that contain infected Word, PDF or Excel files attached. The malware enables criminals to gather confidential information on infected machines and control them.

Their identified victims are the Ministry of Commerce in Myanmar, public and private companies, two German companies in the automotive industry, enterprises in Canada, India, Singapore, as well as US government agencies.

APT name	Regions attacked	Operation start
“Prikormka” (Groundbait).	Ukraine	2016

The ESET company detected a targeted cyber-espionage campaign in Ukraine. The operation named Groundbait (Prikormka) attacks anti-government separatists in the self-declared Donetsk and Luhansk People’s Republics, as well as Ukrainian government officials, politicians and journalists. Criminals use a spy program with modular architecture, which enable them to develop its functionality and steal various data and files. The malware propagates using phishing emails.

Attacks are organized from the territory of Ukraine and the control system operates in the Ukrainian language.

Hacktivism

In Q2 2016, hacktivists conducted over 1900 attacks on various online resources. 826 detected attacks were of “page replacement” type (Deface) and 1027 attacks were DDoS attacks (Denial of Service) targeting government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Israel, the USA, Turkey, Russia, Peru, the UK, India, Japan and Brazil. The most active gangs which are believed to have concentrated their attacks on one country were ActivistHack (attacks on Turkish resources), DownSecBelgium, AnonymousBelgie (attacks on Belgium government resources), DownSecFrance (attacks on French resources), as well as groups which identified themselves with a certain country: AnonyOpTurkey, Anonymous Nigeria, Anonymous Africa, Anonymous Peru, IndiaHackOps and Peruvian Hackers.

The table below contains information on the major hacktivists’ operations conducted in Q2 2016.

Operation name	Regions attacked	Operation start	Types of attacks during the operation
OpAfrica	Eastern Africa, Southern Africa	30.12.2015	DDoS, Deface, Data leakage
	During the operation attacks were conducted against government, financial and non-public organizations of Madagascar, Kenya and the Republic of South Africa. Over 96% of attacks during the operation were conducted by the New World Hackers gang, which actively participated in the operation start in Q1 2016. Resources of the Central Bank of Kenya and the Department of Home Affairs of South Africa are known to be hit with cyberattacks.		
OpIcarus	North America, South America, South America, Southern Europe, Western Europe, Northern Europe, East Africa, Central Africa, South Asia, Southeast Asia, Southwest Asia, Western Asia, East Asia, Polynesia, Australia and New Zealand	03.05.2016	DDoS, Deface
	During the operation hackers attacked banking and financial institutions of various countries. Group-IB specialists detected 167 attacks in total, 34 attacks were conducted by the Ghost Squad Hackers gang. At the first stage of the operation websites of central banks all over the world became victims of attacks, later hacktivists started attacking websites of financial institutions and stock exchanges.		
OpISIS	ISIS, Middle East, Islamic organizations all over the world	11.08.2014	DDoS
	During the OpISIS operation hackers attacked websites related to terrorism as well as religious and information Islamic websites and media resources. In Q2 2016 197 attacks were detected in total with a major part of them organized by BinarySec, TouchMyTweets, and GhostSec hacker groups.		
OpTrump	North America	12.12.2015	DDoS
	During the operation hackers attacked websites related to Donald Trump, an American businessman and politician. Their goal is to “dismantle” Trump’s campaign for the US presidential elections.		
OpKKK	North America, Northern Europe	06.11.2015	DDoS
	During the operation hackers attacked websites related to neo-Nazis groups in the USA and Europe, including resources of organizations, which identify themselves with the Ku Klux Klan movement.		
OpIsrael	Southwestern Asia	07.04.2013	DDoS, Deface, Data leakage
	OpIsrael is an annual operation against Israeli websites and online resources. During the operation hacktivist groups attack government, educational,		

	banking and non-governmental resources and media portals. The operation starts on April 7th every year.		
OpBEAST, OpWhales, OpKillingBay	North America, Northern Europe, Southeast Asia		DDoS
	OpBEAST, OpWhales and OpKillingBay operations were started by various hacker groups in order to attract public attention to animal protection issues. Initially they had targeted websites of entertainment theme parks, water parks and zoos to have further focused their attention on resources belonging to seafood suppliers and technology conglomerates which were considered to damage ecology. At the moment, the hacktivists target websites of Japanese financial and government organizations, Norwegian government organizations, Icelandic seafood restaurants.		

One of the major hacktivist campaigns in Q2 2016 was Operation Icarus targeting websites of financial institutions, banks and government entities. The operation was organized by the following powerful hacktivist groups: Ghost Squad Hackers, New World Hackers, Keylosec and Anonymous Resistance. In total, 167 attacks were conducted on 119 unique resources during the operation with multiple attacks on some of them. The table below contains a list of attacked critical resources divided into categories.

Financial sector		Banking sector	Business sector	Government sector
lseg.com	euronext.com	centralbank.go.ke	helex.gr	georgesoros.com
cse.com.cy	blackstone.com	bis.org	obrela.com	treasury.gov.pg
fanniemae.com	rothschild.com	snb.ch	glencore.com	rbz.co.zw
banque-centrale.mg	batstrading.com	bcv.org.ve	iadb.org	cbm.gov.mm
reservebank.to	lloydsbank.com	stlouisfed.org	orderofmalta.int	bnm.gov.my
privatebankingandtrust.rothschild.com	chase.com	frbsf.org	brb.bi	rbf.gov.fj
sibex.ro	nbp.com.pk	kansascityfed.org	edmond-de-rothschild.com	bvifsc.vg
boerse-muenchen.de	bma.bm	unionbankcameroon.com	bct.gov.tn	suomenpankki.fi
otcei.net	bcu.gub.uy	rbi.org.in	bihargraminbank.in	rbnz.govt.nz
cse.lk	centralbank.org.bz	bankofscotlandbusiness.co.uk	bol.gov.la	riksbank.se
pse.com.ph	bankofamerica.com	cbbank.com	gfsc.gg	
ise.org	bank-of-africa.net	centralbank.ae		
croatiabanka.hr	bcc.cd	pnb.com.ph		
dse.co.tz	nbe.gov.et	bok.or.kr		
bolsadecaracas.com	cryptsy.com	cbj.gov.jo		
tase.co.il	dnb.nl	bankofgreece.gr		
panabolsa.com	centralbank.gov.cy			
londonstockexchange.com				

Data leakage

The Bozkurtlar hacker group disrubted the Qatar National Bank's network and stole personal data of the wealthiest and the most powerful people in the country. The released archive contains information about the Qatari royal family, government and army officials, as well as people listed as working for intelligence agencies of several countries.

The file named SPY is the one that contains abovementioned information on the Qatari royal family, the Qatar's intelligence agency "Mukhabarat" and the Ministry of Defence. Other documents reportedly belong to alleged UK, French and Polish intelligence agents.

Also, leaked data contains files about more than 1200 employees of the world-famous TV company founded and financed by the Qatari royal family. The documents contain their addresses, contact details, links to social media accounts and photos.

- The Bill, Hillary and Chelsea Clinton Foundation's network and servers of the US Democratic Party and Hillary Clinton's presidential campaign suffered hacker attacks.